

CONTROLLER Customer The entity identified in the applicable order form or service agreement with Flintwood LLC.	PROCESSOR Flintwood LLC A Delaware limited liability company providing automated SOC 2 readiness scanning services. Contact: hello@flintwood.io
---	---

SECTION 1

Nature and Purpose of Processing

Flintwood processes AWS configuration metadata from Controller's AWS environment for the sole purpose of generating SOC 2 readiness reports. Processing occurs once per calendar month by assuming a read-only IAM role deployed and controlled by Controller. No data is collected or processed outside this purpose.

SECTION 2

Data Accessed

DATA TYPE	EXAMPLES	ACCESSED
IAM configuration	Policies, roles, user credential age, MFA status, access key age	YES
CloudTrail configuration	Trail enablement, log validation, S3 target, multi-region status	YES
GuardDuty & Config	Detector status, active findings severity, Config recorder status, rule results	YES
S3 bucket metadata	Public access block settings, bucket policies, encryption config, versioning	YES
Lambda & AI services	Function configurations, execution roles, Bedrock/SageMaker permissions and logging config	YES
S3 object contents	Files, application data, backups, database dumps	NEVER
Application secrets	Secrets Manager values, SSM parameter values, environment variables	NEVER
End-user personal data	Customer records, PII, financial data stored in Controller's databases or S3	NEVER

SECTION 3

Access Mechanism & Controller Rights

Controller deploys a read-only IAM role via CloudFormation. Flintwood assumes this role using AWS STS with a Controller-specific External ID, preventing confused-deputy attacks. Every role assumption is recorded in Controller's CloudTrail logs.

Controller may revoke access at any time by deleting the IAM role or CloudFormation stack. No support ticket or offboarding process is required. Access is revoked instantly.

SECTION 5

Sub-processors

SUB-PROCESSOR	SERVICE	LOCATION	PURPOSE
Amazon Web Services, Inc.	RDS, S3	us-east-1	Encrypted storage of scan findings and reports
Amazon Web Services, Inc.	SES	us-east-1	Report delivery via email

SECTION 6

Security Measures

SECTION 4

Retention & Deletion

Scan findings and configuration snapshots are retained for **24 months** to support month-over-month trend reporting. PDF reports are retained for **36 months**.

Upon written request or termination of the service agreement, Flintwood will permanently delete all Controller data within **30 days** and provide written confirmation. Controller retains copies of all delivered reports.

SECTION 7

Breach Notification & Audit Rights

Encryption at rest: AES-256 (S3 SSE, RDS storage encryption)
Encryption in transit: TLS 1.2 or higher for all data transfer
Access control: IAM least-privilege; External ID on all cross-account role assumptions
Audit logging: All access to Controller's AWS environment logged in Controller's CloudTrail

Flintwood will notify Controller without undue delay — and within **72 hours** — of becoming aware of a security incident affecting Controller data, with a description of the nature, scope, and likely consequences.

Controller may request written attestation of Flintwood's security controls annually. Flintwood will respond within 30 days.

SECTION 8

Governing Law

This DPA is governed by the laws of the State of Minnesota, without regard to conflict-of-law principles. This DPA forms part of and is incorporated into the Flintwood service agreement between the parties.

Flintwood LLC (Processor)

Signature _____ Date _____

Name / Title _____

Flintwood LLC · hello@flintwood.io · flintwood.io

Customer (Controller)

Signature _____ Date _____

Name / Title / Company _____

Data Processing Agreement v1.0 · May 2026